Enterprise Risk Management Framework: WB Alloys Group

Live client project. ERM design for a £25m, 72-staff engineering group operating across the UK, UAE and USA.

Vedant Audichya · March 2026
Team of 5
BEBA live client project · MSc Business Analysis and Consulting

THE QUESTION

WB Alloys grew from a single-site welding consumables supplier into a three-country engineering group, but its risk management did not grow with it. What has to change, and in what order?

1 The approach is not weak, it is the right approach for a company that no longer exists

Fragmented, reactive and operationally focused risk management was appropriate for a single-site enterprise. Applied to a diversified multinational, the same practices leave strategic and financial risk unmonitored.

2 Four governance gaps, and the blind spots they create

No enterprise-wide risk register, inconsistent assessment practice, limited board oversight and unmonitored strategic and financial risk. The resulting blind spots are cyber risk, key-person dependency, geopolitical exposure and commodity price volatility.

3 Structure before tooling

A three-layer governance architecture and a seven-phase risk lifecycle were designed first, aligned to ISO 31000:2018, COSO (2017) and IRM. A standardised taxonomy and centralised digital register then make consistency enforceable rather than aspirational.

4 ERM positioned as a capability, not a compliance function

The framework is argued as a strategic capability supporting growth and decision-making under uncertainty. That framing determines whether the board sponsors it or delegates it, which in turn determines whether it survives its first year.

LIMITATIONS AND HONEST CONSTRAINTS

This is a designed framework, not an implemented one, so nothing here is validated by operating evidence. The risk profile was built from client-supplied material rather than from interviews across the three sites, so the blind spots identified are inferred from governance structure rather than confirmed by everyone carrying the risk. The phased roadmap and maturity model set out a sequence, but the effort estimates behind them are indicative. A framework of this kind succeeds or fails on board sponsorship, and that cannot be designed in.

FRAMEWORK AND METHOD

- **Standards:** ISO 31000:2018, COSO (2017), IRM principles
- **Governance:** three-layer architecture spanning board, executive and operational levels
- **Lifecycle:** seven phases from identification through assessment and response to continuous monitoring
- **Taxonomy:** standardised risk categories enabling enterprise-wide comparison across three jurisdictions
- **Platform:** centralised digital risk register with dashboards, starting on spreadsheets for accessibility
- **Roadmap:** phased implementation with an explicit maturity model

BLIND SPOTS THE CURRENT APPROACH CANNOT SEE

- **Cyber risk** across three jurisdictions with differing regulatory exposure
- **Key-person dependency** in a 72-staff organisation
- **Geopolitical exposure** from UK, UAE and USA operations
- **Commodity price volatility** in alloy and consumables inputs
- **Strategic and financial risk**, currently outside any monitoring cycle

Built with ISO 31000:2018 · COSO 2017 · IRM · risk taxonomy design · maturity modelling

Delivered governance architecture · seven-phase lifecycle · risk taxonomy · register and dashboards · phased roadmap